

Internal Penetration Test Report of Findings

MetaBananaCat S.r.l.

NemiSec

Emy Mangogna – emanuela.mangogna@gmail.com

20/9/2025

Table of contents

Engagement Contacts.....	p2
Executive Summary.....	p2
○ Approach.....	p2
○ Scope.....	p2
○ Assessment overview & recommendations.....	p3
Network Penetration Test Assessment Summary.....	p4
○ Summary of findings.....	p4
Internal Network Reconnaissance Walkthrough.....	p5
○ Detailed Walkthrough.....	p5
○ Summary info gathered.....	p5
Remediation Summary.....	p6
○ Short term.....	p6
○ Medium term.....	p6
○ Long term.....	p6

Engagement Contacts

MetaBananaCat Contacts		
Primary Contact	Title	Primary Contact Email
Mr FlyffyChonk	Chief Executive Officer	chonk@miao.com
Secondary Contact	Title	Secondary Contact Email
Mr Wiskerpuff	Chief Technical Officer	purrrpurrr@miao.com

Assessor Contacts		
Assessor Name	Title	Email
Emy Mangogna	Security Consultant	emanuela.mangogna@gmail.com

Executive Summary

MetaBananaCat S.r.l. (“MetaBanana” di seguito) ha incaricato **NemiSec** di eseguire un test di penetrazione della rete interna al fine di identificare punti deboli di sicurezza, valutare il loro impatto sull’azienda, documentare i risultati in modo chiaro e ripetibile e fornire raccomandazioni di mitigazione.

Approach

I test sono stati condotti in modalità black-box, senza credenziali fornite. L’attività ha previsto tecniche di ricognizione e scansione non invasive e controllate finalizzate a identificare servizi esposti, versioni software e configurazioni insicure. Tutte le vulnerabilità rilevate sono state documentate e corredate di raccomandazioni operative per la mitigazione.

Scope

Valutare la superficie d’attacco e individuare vulnerabilità nei sistemi interni di **MetaBananaCat** al fine di fornire raccomandazioni di mitigazione.

Asset In-Scope:

Host/IP Address	Description
192.168.50.	Server interno MetaBananaCat

Tipo di test: black-box interno — nessuna credenziale fornita; attività svolte da un account non autenticato sulla rete interna.

Limitazioni e vincoli: esclusione di attività intrusive o distruttive su sistemi di produzione; nessuna modifica persistente apportata agli host target;

Assessment Overview and Recommendations

Durante il penetration test interno, Emy Mangogna ha identificato diverse vulnerabilità di configurazione che possono compromettere la **riservatezza, integrità e disponibilità** dei sistemi di **MetaBananaCat**.

Le principali criticità rilevate includono:

- **Servizi esposti con credenziali deboli o predefinite.**
- **Condivisioni di rete con permessi troppo ampi**, che potrebbero portare a perdita o divulgazione non intenzionale di dati.
- **Scarsa visibilità e monitoraggio** delle attività interne, che renderebbero difficile rilevare un attacco reale.

Recommendations

- Forzare l'uso di credenziali robuste e uniche per i servizi critici.
- Ridurre i permessi eccessivi sulle cartelle condivise.
- Migliorare il logging e la capacità di rilevare attività sospette.

Network Penetration Test Assessment Summary

Le attività di testing sono state eseguite dalla prospettiva di un utente non autenticato sulla rete interna. L'unico dato iniziale disponibile era l'intervallo IP della rete interna di MetaBananaCat; non erano fornite informazioni sui sistemi operativi o sulle configurazioni dei dispositivi.

Summary of Findings

Durante il corso delle scansioni con Nmap, sono state identificate varie porte aperte e servizi attivi, oltre a informazioni sul sistema operativo.

Finding	Severity	Description
Porte e servizi aperti rilevati	High	Identificazione di porte TCP aperte e servizi attivi che potrebbero rappresentare potenziali vettori di attacco.
Sistema operativo rilevato	Medium	Identificazione del sistema operativo Linux 2.6.X tramite OS fingerprinting.
Version detection servizi	Low	Rilevamento delle versioni dei servizi attivi (FTP, SSH, HTTP, MySQL, ecc.).

Porta	Servizio	Versione/Dettagli	Severità
21	FTP	vsftpd 2.3.4	Mid
22	SSH	OpenSSH 4.7p1	High
23	Telnet	Linux telnetd	High
25	SMTP	Postfix smtpd	Mid
53	DNS	ISC BIND 9.4.2	Mid
80	HTTP	Apache 2.2.8 (Ubuntu)	High
139	SMB	Samba 3.X-4.X	High
445	SMB	Samba 3.X-4.X	High
3306	MySQL	MySQL 5.0.51a	Mid
5432	PostgreSQL	PostgreSQL 8.3	Mid
5900	VNC	VNC protocol 3.3	Mid
6667	IRC	UnrealIRCd	Mid

Internal Network Reconnaissance Walkthrough

Durante l'assessment, sono state eseguite tutte le attività di raccolta informazioni dalla prospettiva di un utente non autenticato sulla rete interna di **MetaBananaCat**. Le fasi descritte di seguito mostrano i passaggi principali eseguiti per identificare sistemi, porte aperte, servizi e versioni software, e per stimare il sistema operativo dei target.

Detailed Walkthrough

1. Scansione iniziale e host discovery

È stato verificato che l'host 192.168.50.20 fosse attivo tramite ping e scansioni TCP di base.

2. OS Fingerprinting

Con il comando `nmap -O 192.168.50.20` è stato identificato il sistema operativo stimato del target: Linux kernel 2.6.X.

3. SYN Scan (TCP Half-Open Scan)

Con `nmap -sS 192.168.50.20` sono state enumerate le porte aperte in modalità stealth.

4. TCP Connect Scan

Con `nmap -sT 192.168.50.20` è stato confermato lo stato delle porte aperte in modalità completa (TCP handshake completo).

5. Version Detection

Con `nmap -sV 192.168.50.20` è stata determinata la versione dei servizi in ascolto.

Summary info gathered

- **IP target:** 192.168.50.20
- **Sistema operativo stimato:** Linux 2.6.X
- **MAC Address:** 08:00:27:09:7A:98 (Oracle VirtualBox NIC)
- **Porte aperte principali:** 21/tcp (FTP), 22/tcp (SSH), 23/tcp (Telnet), 25/tcp (SMTP), 80/tcp (HTTP), 3306/tcp (MySQL), 5432/tcp (PostgreSQL), 5900/tcp (VNC)
- **Servizi con versione:** vsftpd 2.3.4, OpenSSH 4.7p1, Apache httpd 2.2.8, MySQL 5.0.51a-3ubuntu5, UnrealIRCd, ProFTPD 1.3.1, Samba smbd 3.X-4.X

Remediation Summary

Short Term

- Disabilitare o limitare l'accesso ai servizi non necessari (Telnet, FTP, VNC).
- Aggiornare i servizi identificati con versioni obsolete (es. vsftpd 2.3.4, Apache 2.2.8, OpenSSH 4.7p1).
- Impostare credenziali forti per i servizi esposti (SSH, Apache, database).

Medium Term

- Effettuare audit periodici delle porte e dei servizi attivi sulla rete interna.
- Verificare configurazioni e permessi dei servizi per ridurre rischi di accesso non autorizzato.
- Implementare firewall o regole di accesso per limitare servizi a host specifici.

Long Term

- Monitoraggio continuo della rete interna per rilevare aperture di porte non autorizzate.
- Pianificare aggiornamenti regolari e gestione delle patch dei servizi interni.
- Formare il personale IT su best practice di hardening dei servizi di rete.